



Week 7 Lecture 6

▼ Class	BSCCS2003
🕒 Created	@October 18, 2021 7:05 PM
🔗 Materials	
# Module #	43
▼ Type	Lecture
# Week #	7

Security of Databases

SQL in context of an application

- Non-MVC app: can have direct SQL queries anywhere
- MVC: only in controller, but any controller can trigger a DB query

So, what is dangerous about queries?

Typical HTML form

```
<form>
  Username:
  <input type="text" name="name">
  <br />
  Password:
  <input type="password" name="password">
  <br />
</form>
```

Username:

Password:

Code

```
name = form.request['name']
pswd = form.request['password']

sql = 'SELECT * FROM Users WHERE Name = "' + name + '" AND Pass = "' + pswd + "'"
```

Example Input vs SQL

Username: *abcd*

Password: *pass*

```
SELECT * FROM Users WHERE Name = "abcd" AND Pass = "pass"
```

Username: " or ""="

Password: " or ""="

```
SELECT * FROM Users WHERE Name = "" or "" AND Pass = "" or ""
```

→ *The above query checks for, basically, nothing and returns everything from the table* **Users**

```
sql = "SELECT * FROM Users WHERE Name = " + name
```

Input:

```
a; DROP TABLE Users;
```

Query:

```
SELECT * FROM Users WHERE Name = a; DROP TABLE Users;
```

Problem

- Parameters from the HTML taken without validation
- Validation:
 - Are they valid text data (no special characters, other symbols)
 - No punctuation or other invalid input
 - Are they the right kind of input (text numbers, email, date)?
- Validation **MUST** be done before the DB query - even if you have validation in the HTML or JavaScript - not good enough
 - Direct HTTP requests can be made with junk data

Web Application Security

- SQL injection
 - Use known frameworks, best practices, validation
- Buffer overflows, input overflows
 - Length of inputs, queries
- Server level issues - protocol implementation?
 - Use known servers with good track record of security
 - Update all patches
- Possible outcomes:
 - loss of data - deletion
 - exposure of data - sensitive information leak
 - manipulation of data - change

HTTPS

- Secure sockets: Secure communication between client and server
- Server certificate:
 - based on DNS: Has been verified by some trusted 3rd party
 - difficult to spoof
 - based on Mathematical properties - ensure very low probability of mistakes match

- However:
 - Only secures the link for data transfer - does not perform validation or safety checks
 - Negative impact on "caching" of resources like static files
 - Some overhead on performance

Summary

- Internet and Web security are complex: Enough for a course in themselves
- Generally recommended to use known frameworks with trusted track records
- Code audits
- Patch updates on OS, server, network stack, etc. essential

App developers should be very careful of their code, but also aware of problems on other levels of stack.